



Mishael Kwaku Yeboah

API SECURITY RISK ANALYSIS REPORT

Task 3 – Cyber Security Internship

LEARN MORE 

APIs Tested: JSONPlaceholder, Fake
Store API, DummyJSON — June 2026

Future Interns | CIN: FIT/MAY26/CS8295 |
Mishael Kwaku Yeboah

Executive Summary

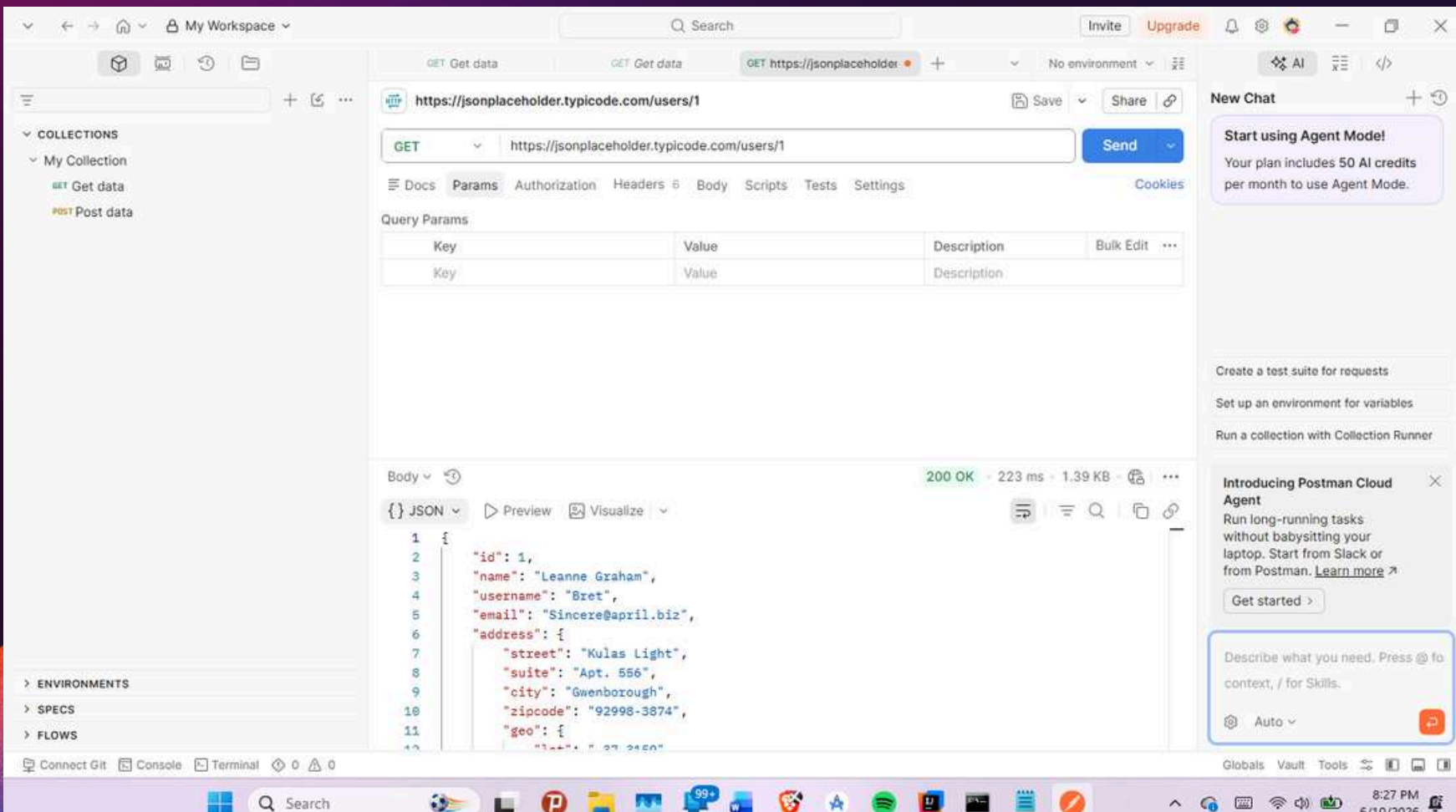
This report analyses three public test APIs (JSONPlaceholder, Fake Store API, DummyJSON) for security weaknesses based on the OWASP API Security Top 10.

Key findings: Missing authentication (no API keys or tokens), excessive data exposure (email, phone, address), IDOR (access any user by changing ID), lack of rate limiting, and weak input validation.

Email Analysis Summary

NO.	Findings	API ENDPOINT	Severity
1	Missing Authentication	/users/{id}	Critical
2	Excessive Data Exposure	/users/{id}	High
3	IDOR (Broken Object Level Authorization)	IDOR (Broken Object Level Authorization)	Critical
4	Lack of Rate Limiting	All endpoints	Medium

Finding 1: Missing Authentication



Test performed:

GET https://jsonplaceholder.typicode.com/users/1

GET https://jsonplaceholder.typicode.com/users/2

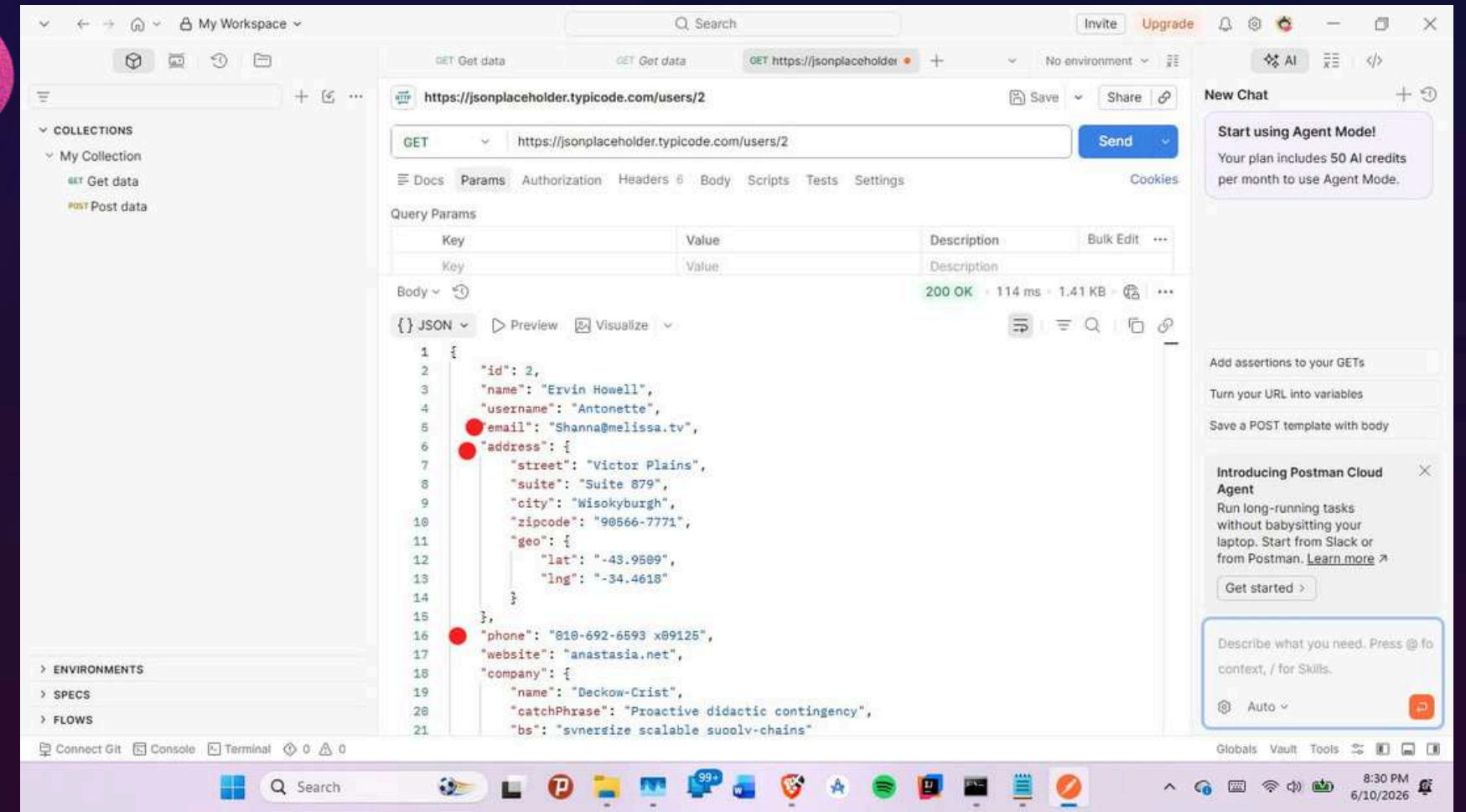
GET https://jsonplaceholder.typicode.com/users/3

Result: All requests returned 200 OK with user data. No API key, token, or login was required.

Risk: Anyone on the internet can access all user data. Attackers can scrape the entire database.

Severity: Critical

Finding 2: Excessive Data Exposure



Test performed:

GET https://jsonplaceholder.typicode.com/users/1

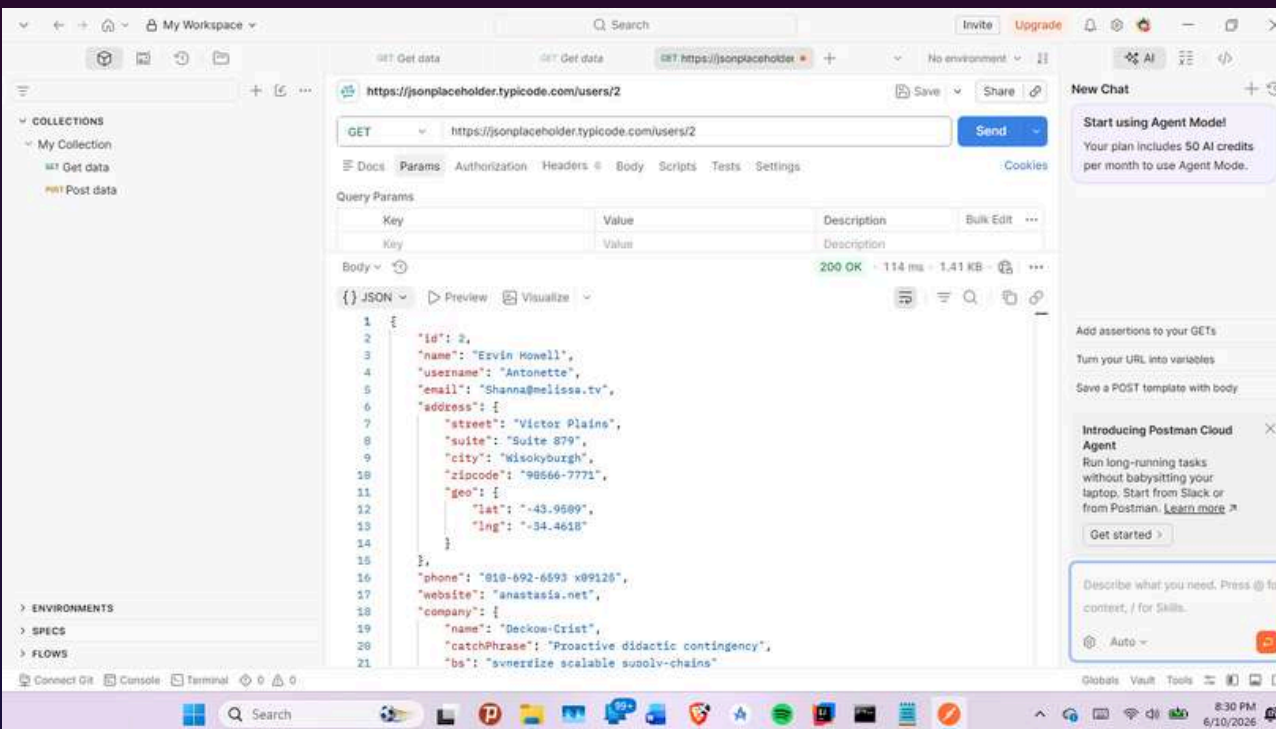
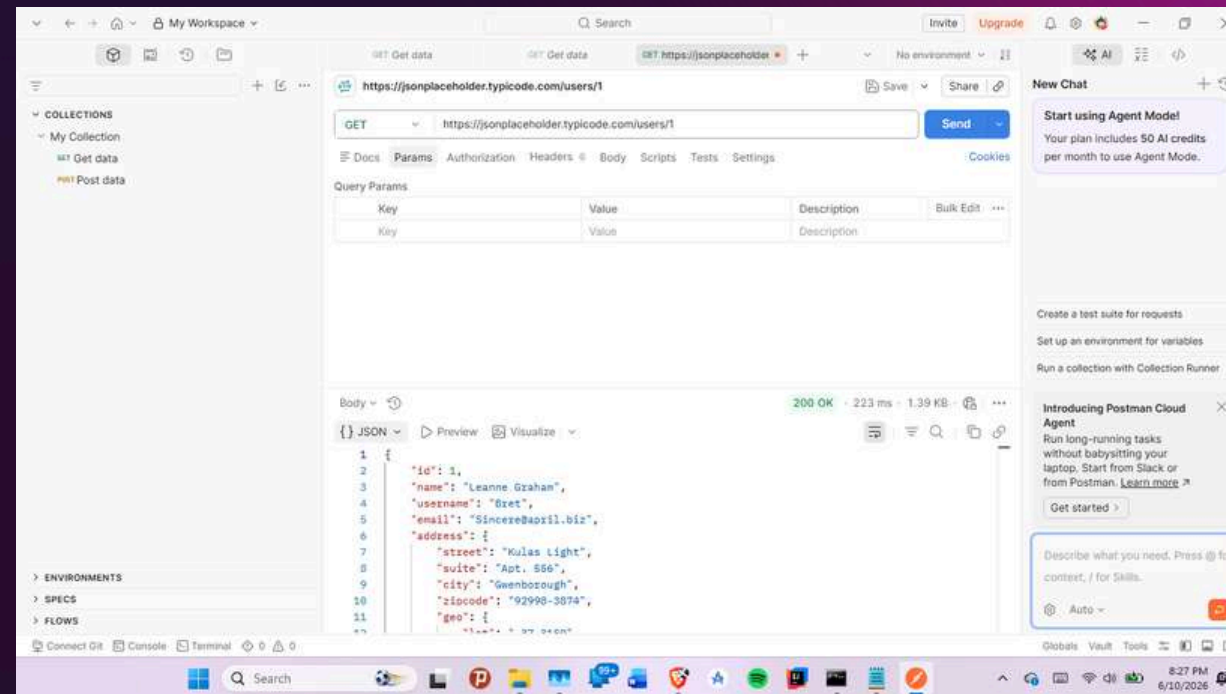
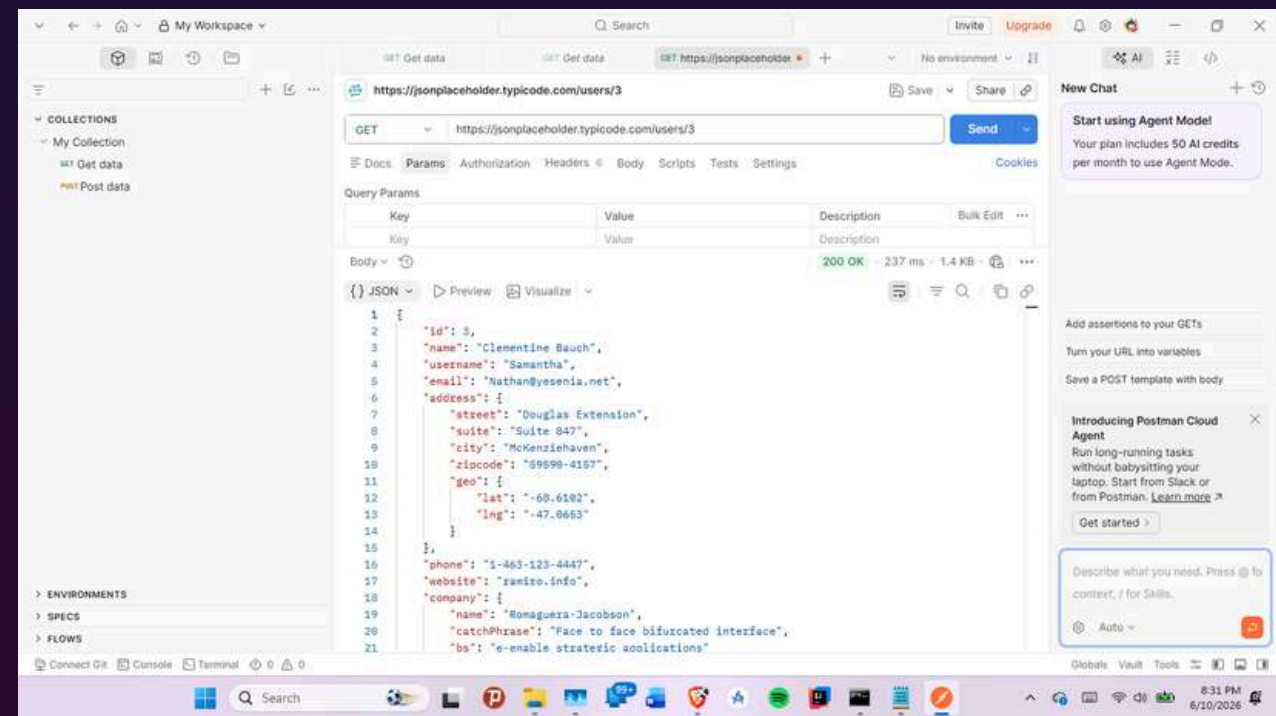
Response returned: id, name, username, email, address (street, suite, city, zipcode, geo), phone, website, company

Sensitive fields exposed: email, phone, full address with geo-location

Why this is a problem: For a public API, returning email addresses and phone numbers violates privacy expectations and can lead to spam or targeted attacks.

Severity: High

Finding 3: IDOR



Test performed:

- User ID 1 → data returned
- User ID 2 → data returned
- User ID 3 → data returned

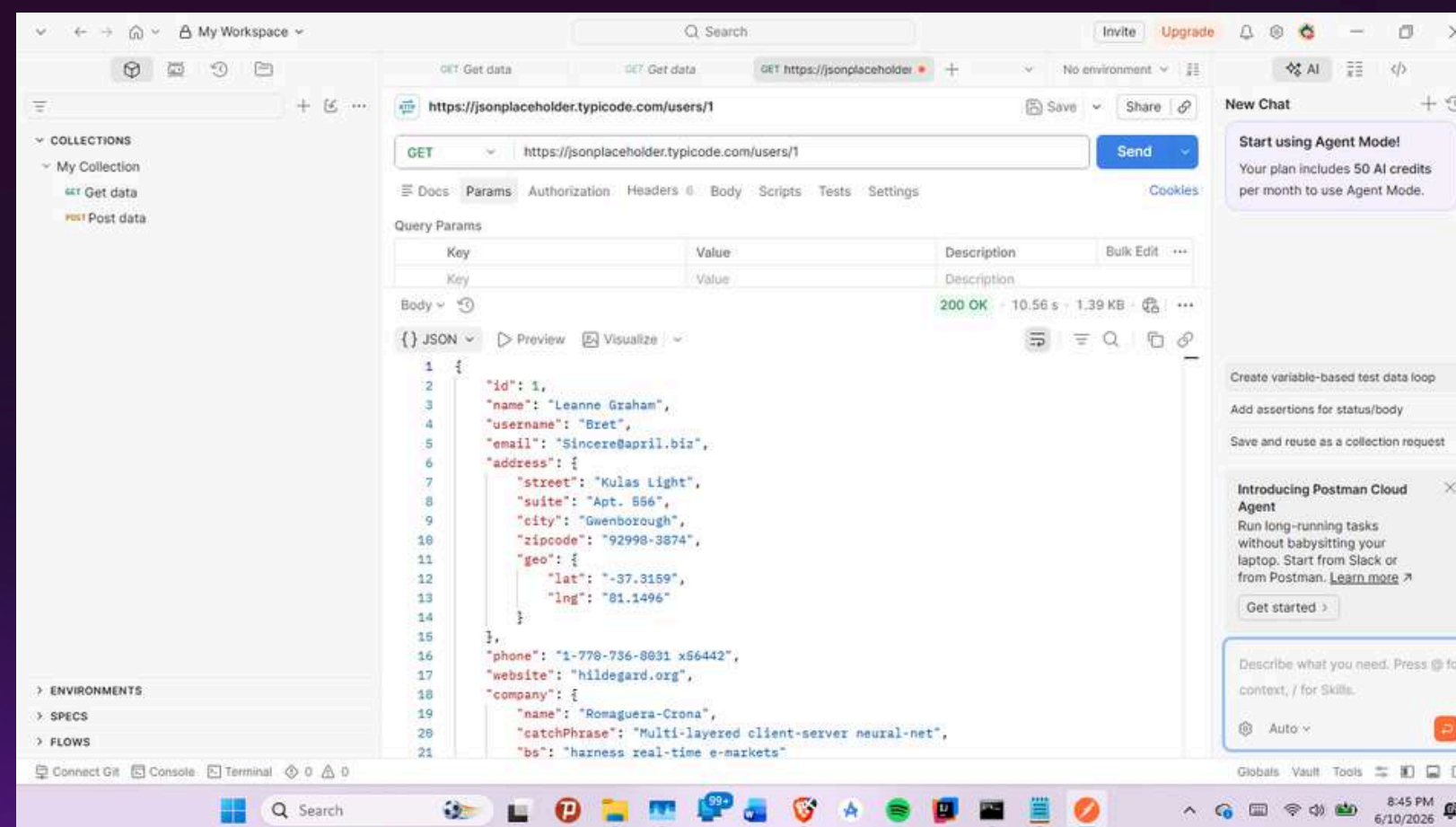
Result: By simply incrementing the user ID in the URL, I accessed data for different users without any permission check.

Risk: An attacker can brute-force user IDs (1, 2, 3, 4, ...) and download all user data, leading to mass data breach.

Severity: Critical

Finding 4: Lack of Rate Limiting

- Test performed:
- Sent 20 rapid GET requests to `https://jsonplaceholder.typicode.com/users/1` within 5 seconds.
- Result: All 20 requests returned 200 OK. No 429 Too Many Requests error was received.
- Risk: Without rate limiting, attackers can:
- Brute-force passwords or user IDs
- Launch Denial-of-Service (DoS) attacks
- Scrape all data in minutes
- Severity: Medium

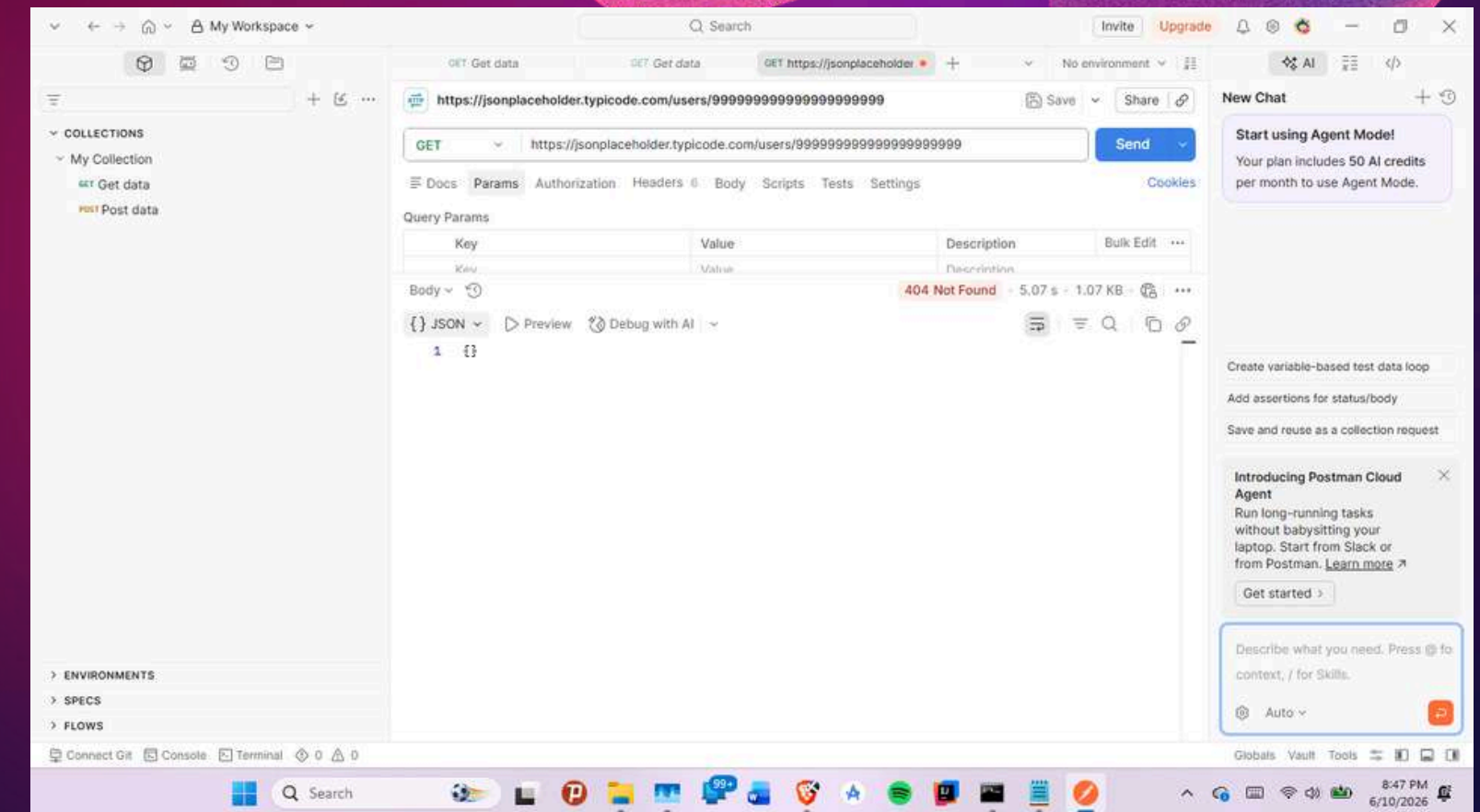
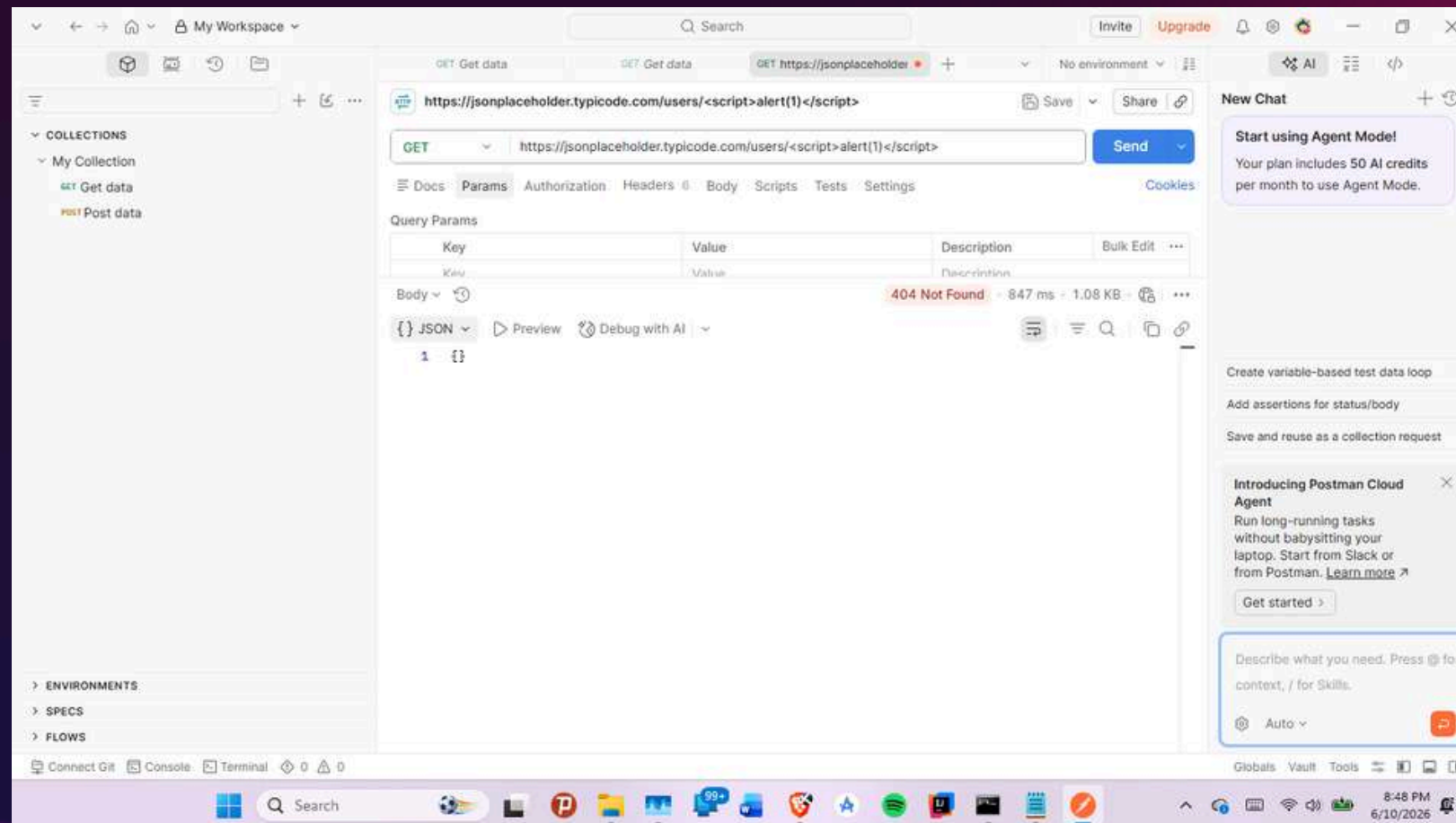


Tests performed:

Test	URL	Response	Verdict
Empty parameter	/users/	Returned user 1 data	Weak (should return 404)
Very long ID	/users/9999999999 9999999999	404 Not Found	Good
XSS attempt	/users/<script>alert(1) </script>	404 Not Found	Good

Conclusion: Partial input validation exists, but empty parameter handling defaults to user 1 instead of rejecting the request.
Severity: Low

Tests performed:



THANK YOU – END OF REPORT

References

- APIs tested: JSONPlaceholder (jsonplaceholder.typicode.com), Fake Store API (fakestoreapi.com), DummyJSON (dummyjson.com)
- OWASP API Security Top 10: <https://owasp.org/www-project-api-security/>
- Test date: June 2026
- Intern: Mishael Kwaku Yeboah
- CIN: FIT/MAY26/CS8295